

THE FUTURIST'S STRATEGY CONE™

A Human-Controlled Governance Framework
for Agentic AI in Internal Audit

4 STAGES: Risk → Audit → Evidence → Reporting



RISK

Identify, assess and prioritize AI risks across processes and data.



AUDIT

Design and perform intelligent audits with AI oversight and human judgment.



EVIDENCE

Capture immutable, traceable and verifiable audit evidence.



REPORTING

Deliver meaningful insights for assurance and decision-making.



Agentic AI
Audit Leader

Predictive
Intelligence

Real-time
Assurance

Stronger
Governance

ADNAN SHAMIM

AGENTIC AI LEADER
INTERNAL AUDIT & AI GOVERNANCE PROFESSIONAL



EMAIL
ad.shamim1985@gmail.com



MOBILE
03138224669



CREATOR OF
**THE FUTURIST'S
STRATEGY CONE™**



Designed for Boards, CFOs & CAEs
to Govern Agentic AI with Confidence



AI Enhances Capability,
Humans Maintain Accountability.



Explore the
Framework
**Scan to
learn more.**



ad.shamim1985@gmail.com



03138224669



linkedin.com/in/
adnan-shamim-802a6622b



DM **"CONE"** for Framework

HOW TO AUDIT AGENTIC AI GOVERNANCE

AI can be accurate—and still be poorly governed.

As AI moves toward autonomy, Internal Audit must change the question.

Not:

- ✗ Is the model accurate?
- ✗ Does an AI policy exist?
- ✗ Is a human “in the loop”?

But:

Can management demonstrate, with sufficient, relevant and reliable evidence, that AI operates within approved purpose, authority, risk and control boundaries—and that controls remain designed, implemented, operating and effective as circumstances change?

1 RISK & ACCOUNTABILITY

- 'n What business process and risk does AI affect?
- 'n What may it recommend, decide or execute?
- 'n Who owns the risk, decision and outcome?

2 PURPOSE 'n AUTHORITY 'n BOUNDARY 'n OVERSIGHT

Purpose — Why is AI used?

Authority — What may it access, decide or execute?

Boundary — Where must it stop?

Escalation — When must it stop, defer or escalate?

Human Oversight — Which decisions require review, approval, intervention or override—and how is that requirement enforced?

Human-in-the-loop is not sufficient.

The real test:

Does required human intervention occur at the defined risk boundary—and can the control prevent bypass?

Defined 'n Authorized 'n Enforced 'n
Monitored 'n Tested 'n Escalated 'n
Revocable

3 TEST CONTROLS – NOT CLAIMS

“Agent cannot approve above X.” ‘n Test it.

“Restricted data cannot be accessed.” ‘n Test the access path.

“Human approval is mandatory.” ‘n Test whether execution is blocked without it.

“Low-confidence decisions require escalation.” ‘n Test the trigger and route.

Assess:

Design ‘n Implementation ‘n Operation
‘n Effectiveness

Declared governance ≠ enforced governance.

4 CHANGE + EVIDENCE

Test material changes to purpose, authority, boundaries, data, models, agents, tools, workflows and dependencies.

'n Were controls reassessed and retested where warranted?

'n Are overrides and exceptions authorized and recorded?

'n Can unauthorized actions be detected, contained and traced?

Evidence chain:

Identity 'n Data 'n Policy 'n Model/
Agent 'n Decision 'n Action 'n

Exception 'n Intervention 'n Outcome

Ask:

“If this decision is challenged six months from now, can management reconstruct what happened, establish who or what authorized each material step, prove required intervention occurred, and determine whether controls operated as intended?”

If not:

The evidence is insufficient to support a credible assurance conclusion.

5 PREVENT 'n CONTAIN 'n STOP 'n RECOVER

For authorized autonomous action:

- 'n Can authority be revoked?
- 'n Can access or tools be disabled?
- 'n Can unsafe or unauthorized continuation be prevented?
- 'n Can the agent be suspended or terminated?
- 'n Is evidence preserved?
- 'n Is resumption subject to authorized controls?

The ability to prevent, contain and stop unauthorized or unsafe action is a control objective.

THIRD-LINE BOUNDARY

Management: Own 'n Design 'n
Implement 'n Operate 'n Monitor 'n
Remediate

Internal Audit: Assess 'n Challenge 'n
Test 'n Conclude 'n Report

Internal Audit provides independent assurance; it does not own or operate management's controls.

THE BOTTOM LINE

Auditable AI Governance requires:

PURPOSE | AUTHORITY | BOUNDARY |
CONTROL | OVERSIGHT | EVIDENCE |
ACCOUNTABILITY | CHANGE | STOP

The decisive question:

“Can management demonstrate that AI remains within approved boundaries, required human oversight is effective, material changes are controlled, and material actions are attributable and reconstructable?”

FROM AUDITING AI

TO AUDITING THE GOVERNANCE AND
CONTROL SYSTEM THAT ENABLES AI
TO OPERATE.

THE FUTURIST'S STRATEGY CONE™

Reimagining Internal Audit for the Age of Agentic AI



By **Adnan Shamim**